

密码应用与访问行为模式保护

cryptographic application and its access pattern protection

姓名：刘哲理

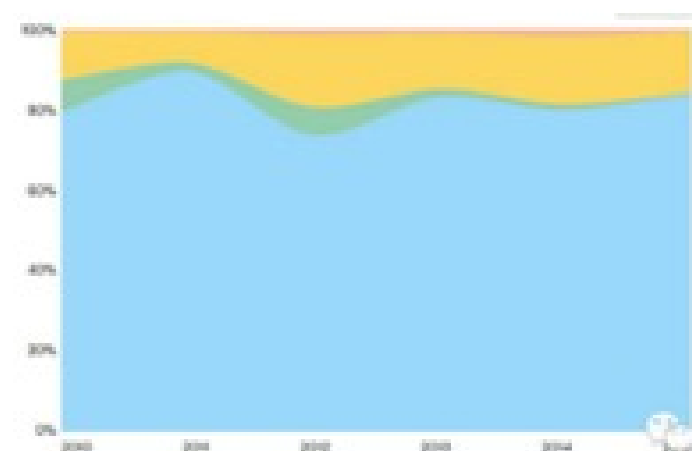
liuzheli@nankai.edu.cn

南开大学

第一部分 密码应用面临的新挑战

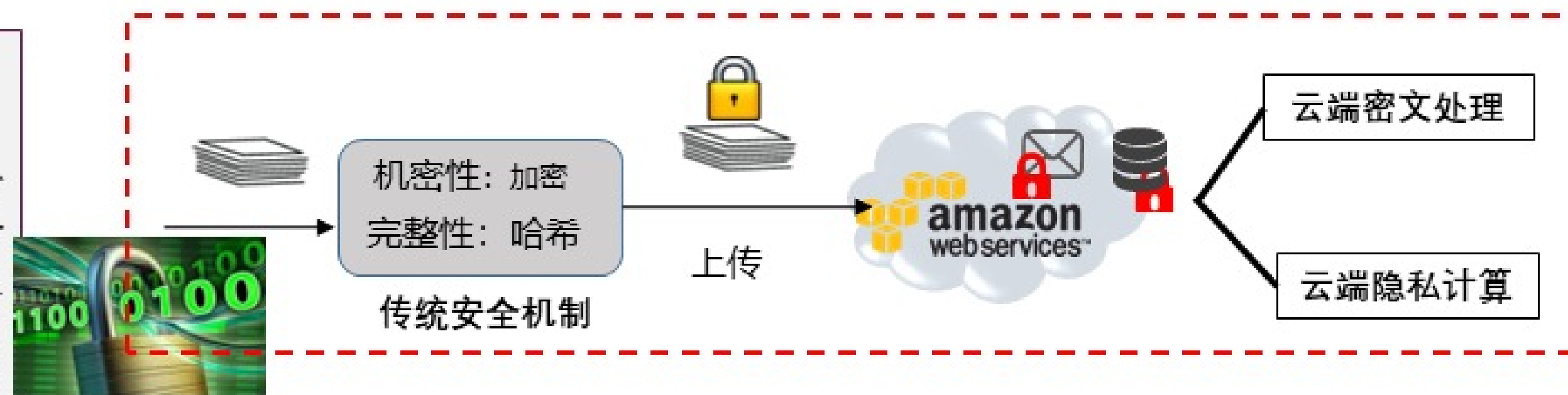
隐私泄露主要原因：明文存储

挑战：数据的安全性和可用性



70%外部攻击/20%内部泄密
75%以经济利益为目的
云计算和云服务导致数据集中和泄密，2016年2月阿里云和淘宝泄密事件

数据明文存储



- 图灵奖得主Shafi Goldwasser在她的论文 "*How to Run Turing Machines on Encrypted Data*" 指出：**传统加密安全方法导致密文数据的运算处理成为困难问题。**
- 可搜索加密、保留顺序加密、CryptDB\ARX密态数据库、安全多方计算等成为研究热点

企业关注数据安全：移动-南开（脱敏溯源）、腾讯-南开（精准广告推荐）、华为-南开（数据库密文查询）

密文关键词检索问题

■适用领域：数据库全文检索\邮件按关键词检索\密文文件查询等

■ **问题描述：**加密后仍能对密文文件、长文本密文数据进行关键词检索，允许不可信服务器无需解密就可以完成是否包含某关键词的判断。

Email system

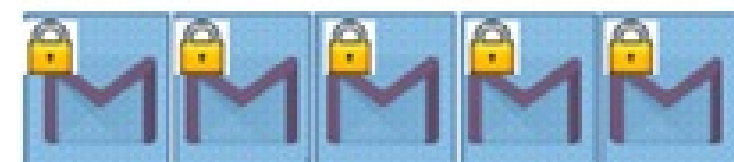
client



Search?



Gmail
by Google



Privacy?

两类典型构造方法

正向索引 D1: $w_1, w_2, \dots$

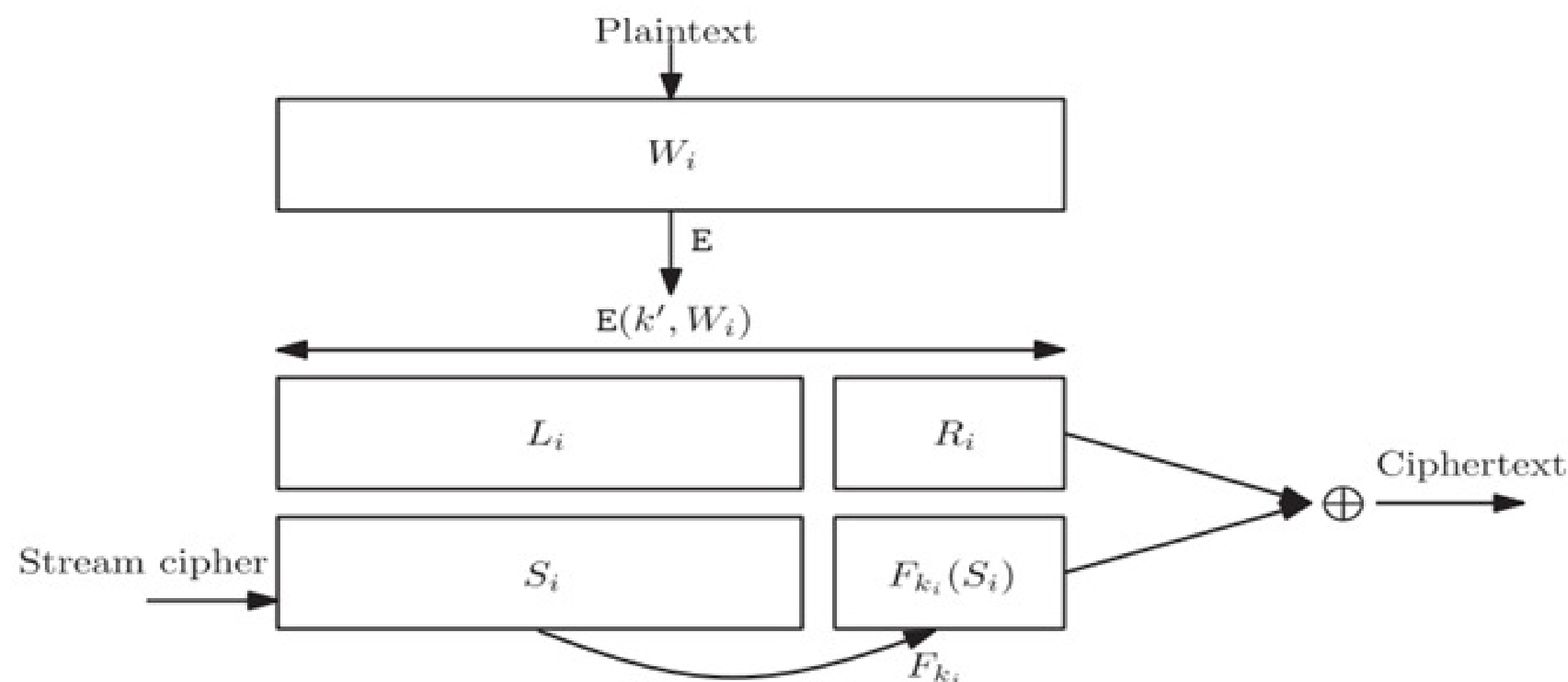


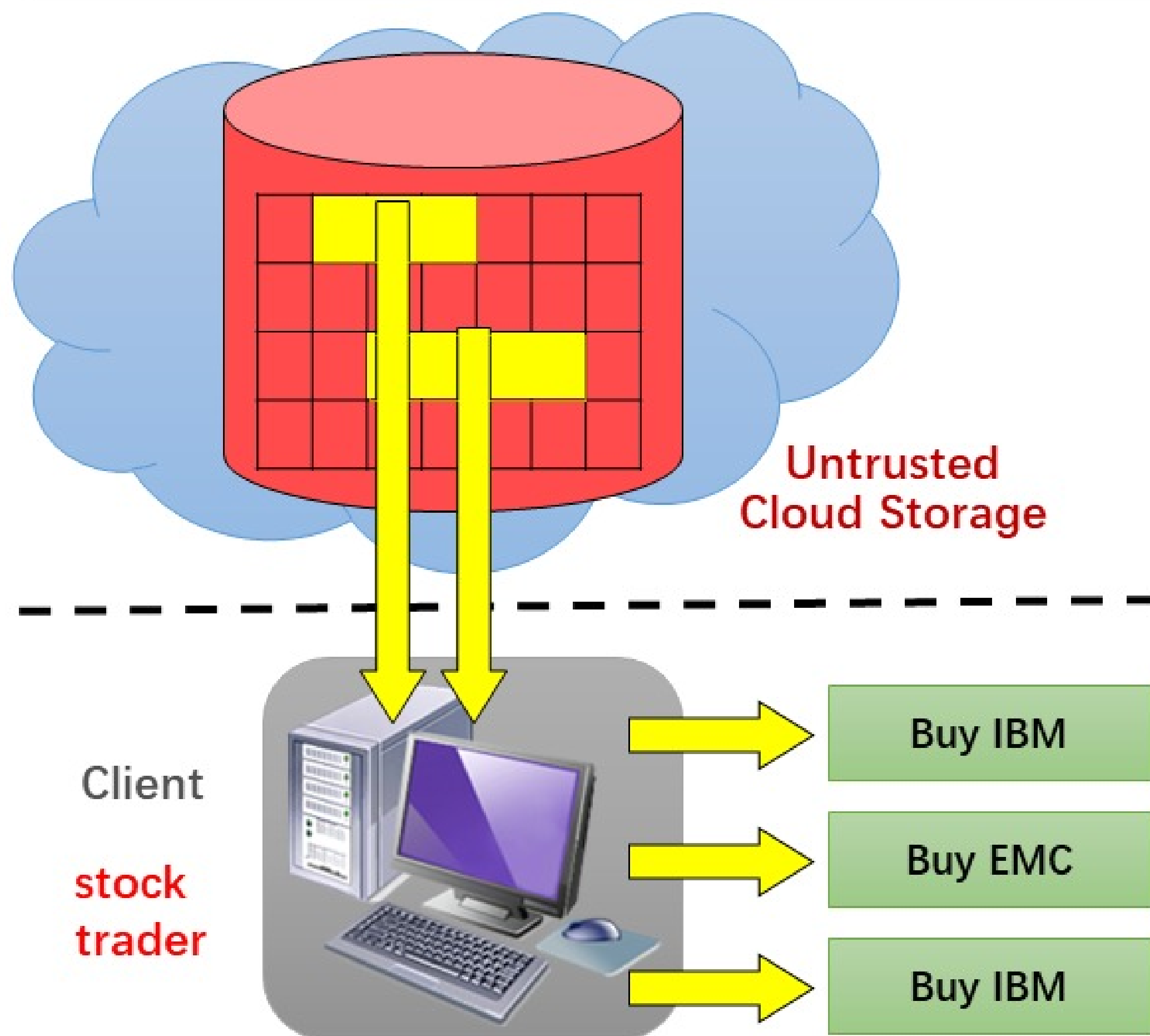
Fig. 5. Song, Wagner and Perrig's Scheme IV Song et al. [2000].

倒排索引

Table VII. A Hypothetical Example of an Inverted Index: Given a Set of n Messages D and m Keywords, w

Key	Value
w_1	$D_1, D_4, \dots, D_{15}$
w_2	$D_1, D_3, \dots, D_{22}$
$\vdots$	$\vdots$
w_m	$D_2, D_3, \dots, D_n$

数据加密面临新挑战：加密已不足以保护隐私，访问行为模式会泄露明文信息



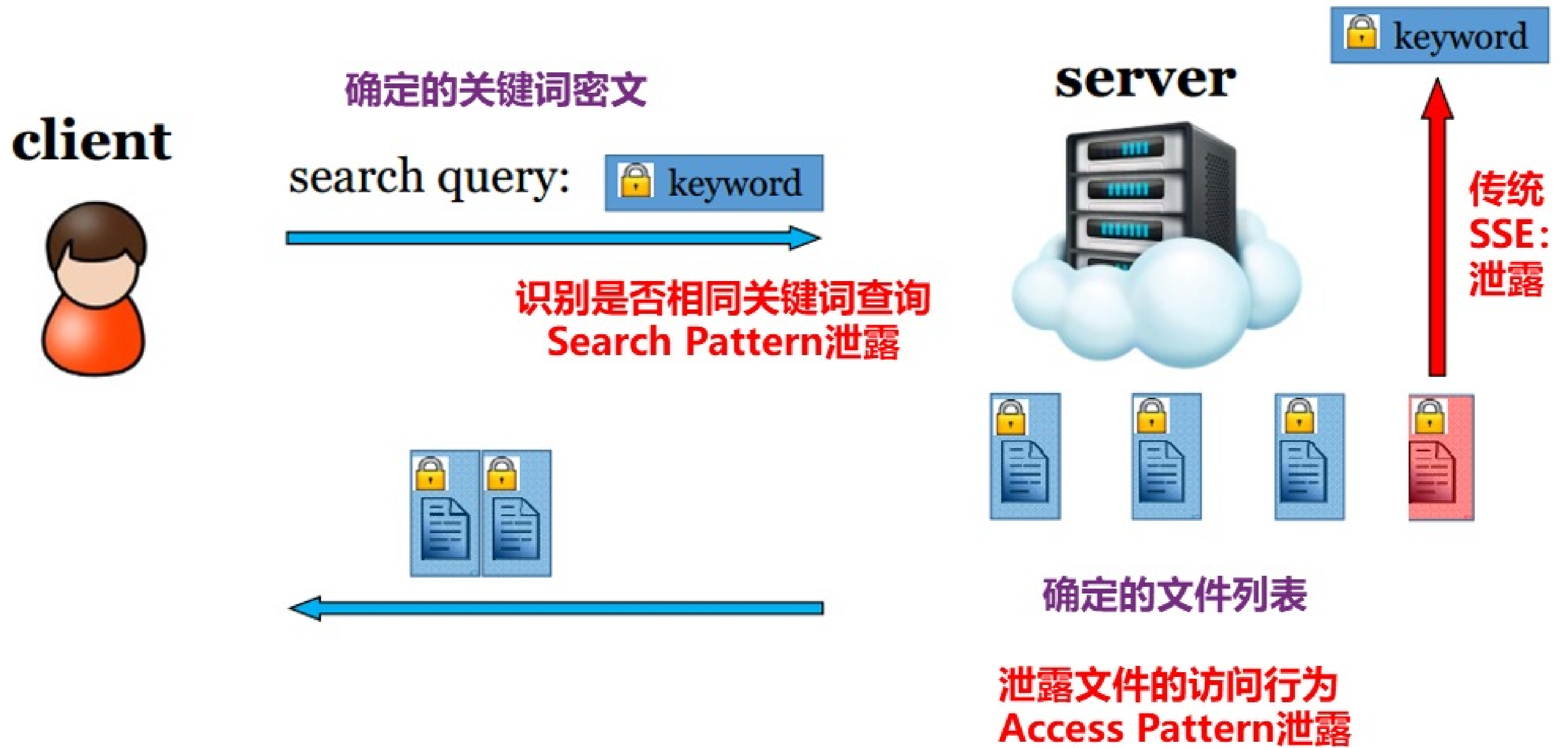
典型攻击事件

➤ Leakage-abuse attacks against searchable encryption. **CCS 2015**. CCF-A

attacker to reveal the client's queries, leading to *leakage-abuse attacks*. For larger leakage, the authors of [CGPR15] show that full plaintext recovery of the encrypted database is possible.

➤ All your queries are belong to us: The power of le-injection attacks on searchable encryption. **USENIX SECURITY 2016**. CCF-A

Their work was improved by the one of Zhang *et al.* in the case of dynamic databases, where the attacker can inject new documents in the database, in [ZKP16]. In this paper, the authors showed a devastating adaptive attack which reveals the content of a past query by inserting as few as 10 new documents. This attack can be run on almost all existing SSE schemes because the server can learn that the newly added document matches a previous search query.



注入攻击

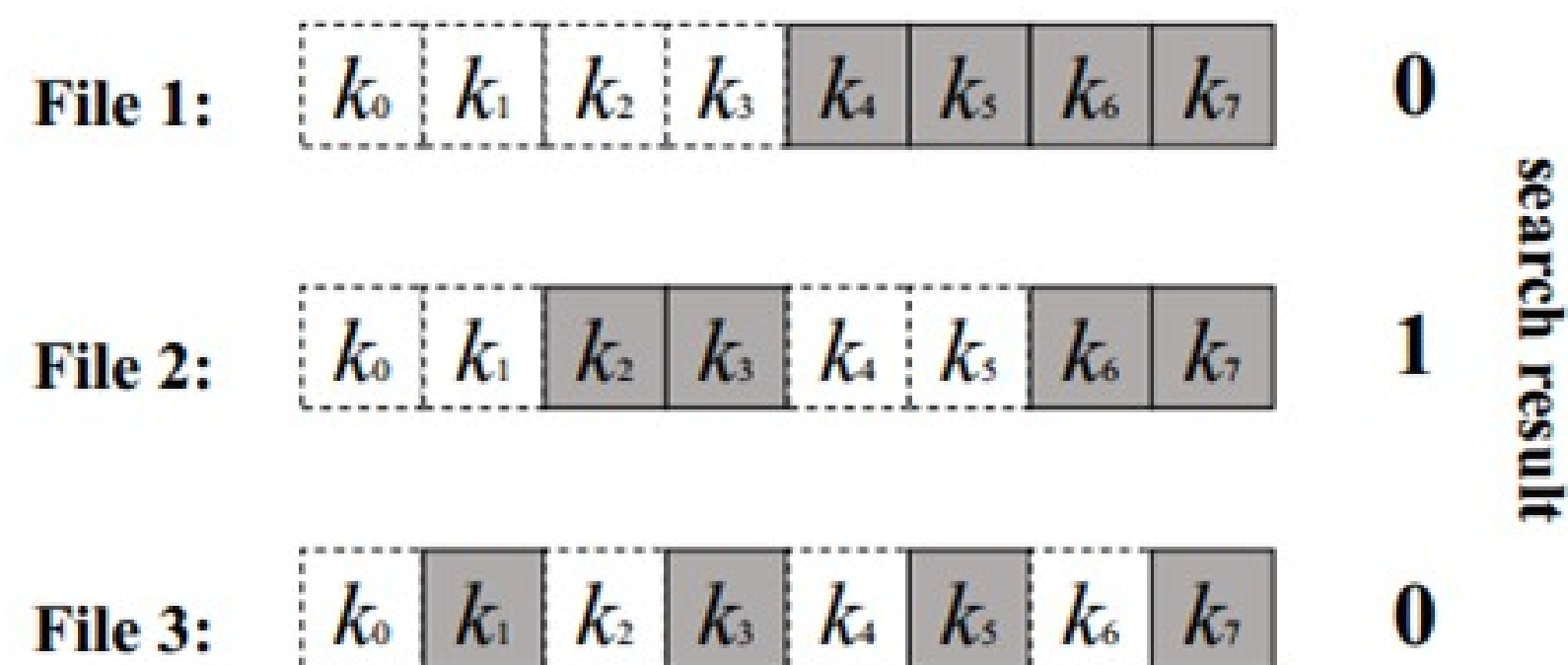


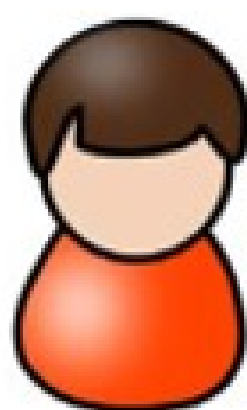
Figure 1: An example of the binary-search attack with $|K| = 8$. Each file injected by the attacker contains 4 keywords, which are shaded in the figure. If file 2 is returned in response to some token, but files 1 and 3 are not, the keyword corresponding to that token is k_2 .

攻击细节

- 对于共有 $K=8$ 个关键词的SE方案，注入 $\log K$ 个文件，每个文件包含 $K/2$ 的关键词。左侧例子注入3个文件。
 - 如果文件File1插入到了某关键词对应的文件列表中，意味着K4
 - 如果文件File2和File3插入到了某关键词对应的文件列表中，意味着K3
 - 如果文件File2插入到了某关键词对应的文件列表中，意味着K2
 -

前向安全(Forward privacy)：插入操作不泄露与过往查询关键词的关联关系，即保护了search pattern

client



确定的关键词密文

search query:  keyword



server



访问的时候：access pattern仍然泄露！

Bost, R. (2016, October). Σ oφoς: Forward Secure Searchable Encryption. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security* (pp. 1143-1154). ACM.

注入攻击

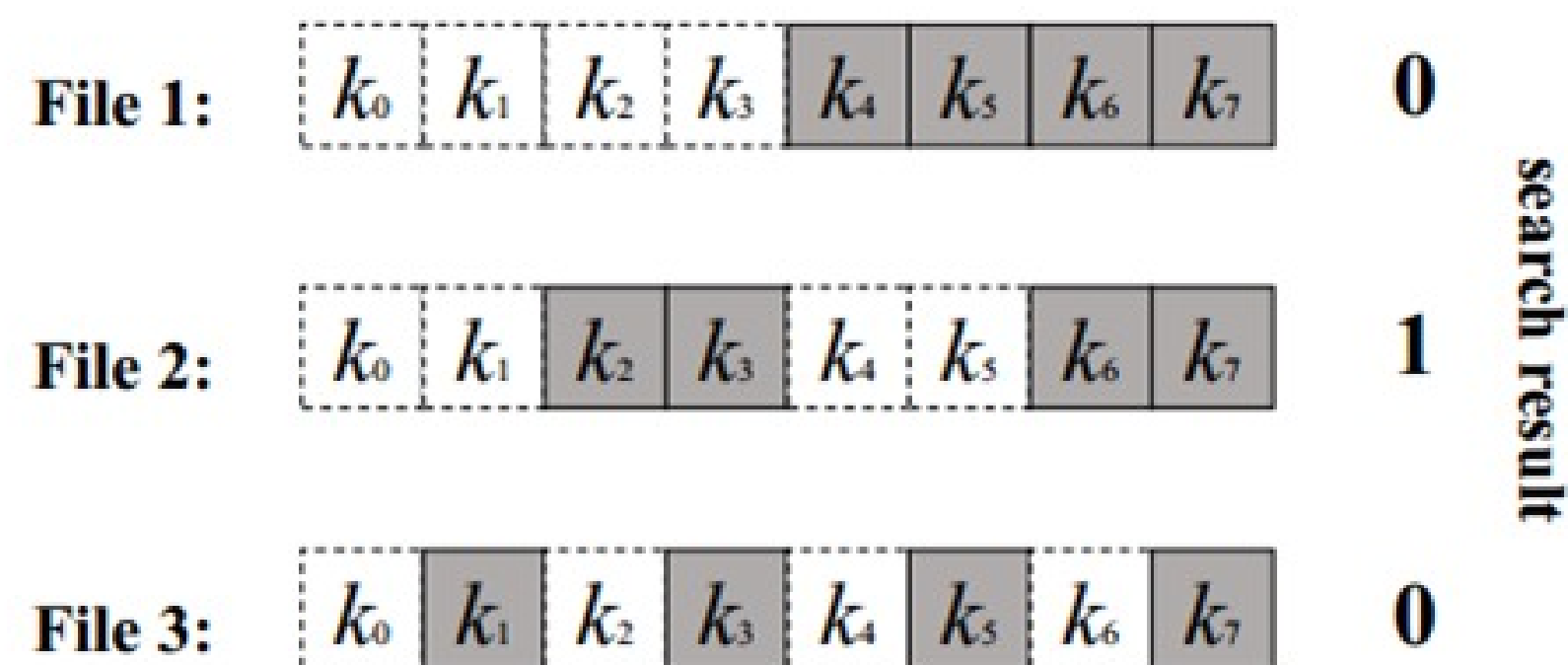


Figure 1: An example of the binary-search attack with $|K| = 8$. Each file injected by the attacker contains 4 keywords, which are shaded in the figure. If file 2 is returned in response to some token, but files 1 and 3 are not, the keyword corresponding to that token is k_2 .

攻击细节

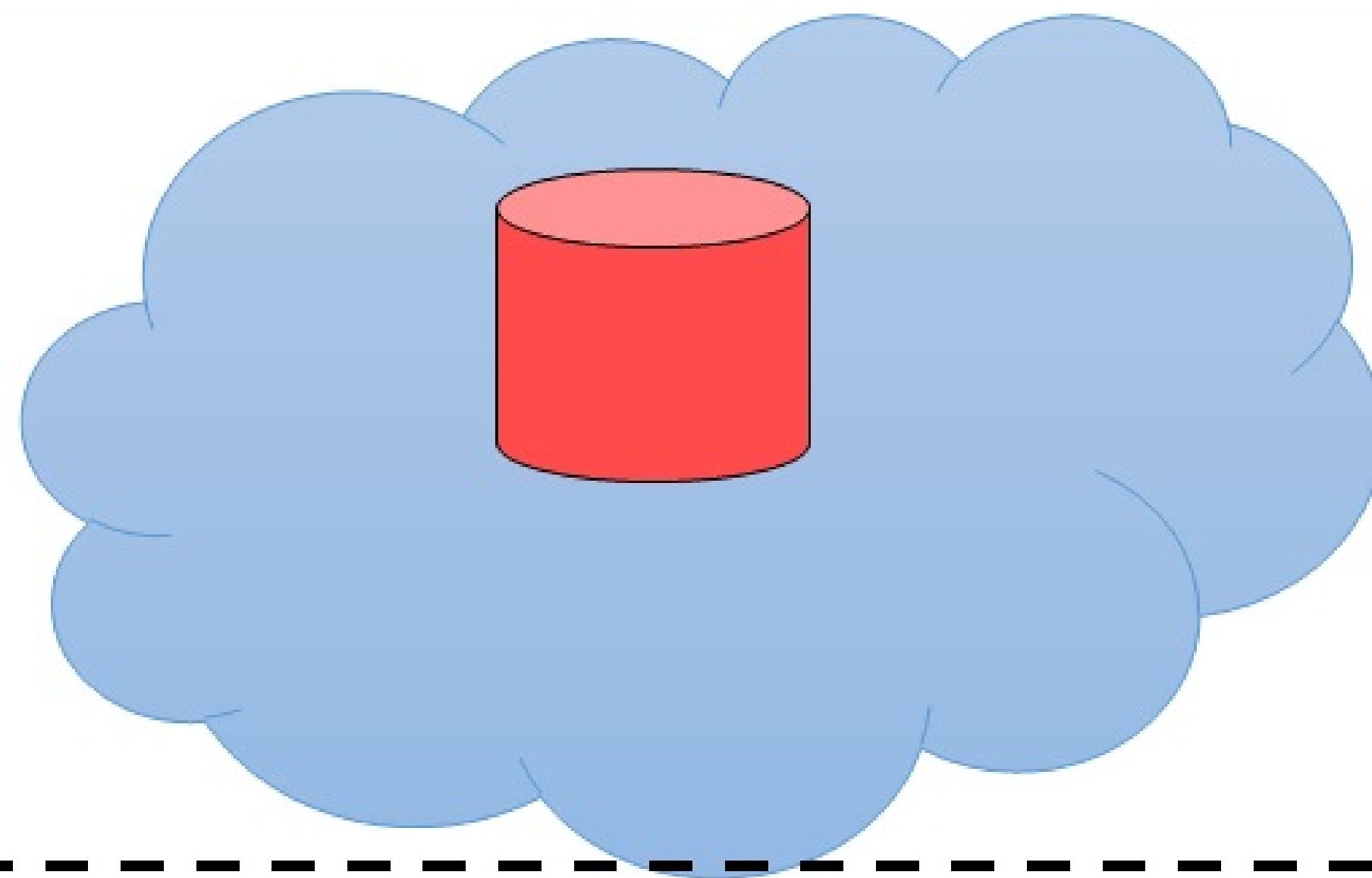
- 对于共有 $K=8$ 个关键词的 SE 方案，注入 $\log K$ 个文件，每个文件包含 $K/2$ 的关键词。左侧例子注入 3 个文件。
 - 如果查询的时候文件 File1 被访问，意味着 K_4
 - 如果查询的时候文件 File2 和 File3 被访问，意味着 K_3
 - 如果查询的时候文件 File2 被访问，意味着 K_2
 -? 前向查询安全?

Li, J., Huang, Y., Wei, Y., Lv, S., Liu, Z., Dong, C., & Lou, W. (2019). Searchable symmetric encryption with forward search privacy. *IEEE Transactions on Dependable and Secure Computing*.

第二部分 如何保护访问行为模式

基本思路就是**茫然读**、**茫然写**，隐藏块的访问模式

不可信
云存储



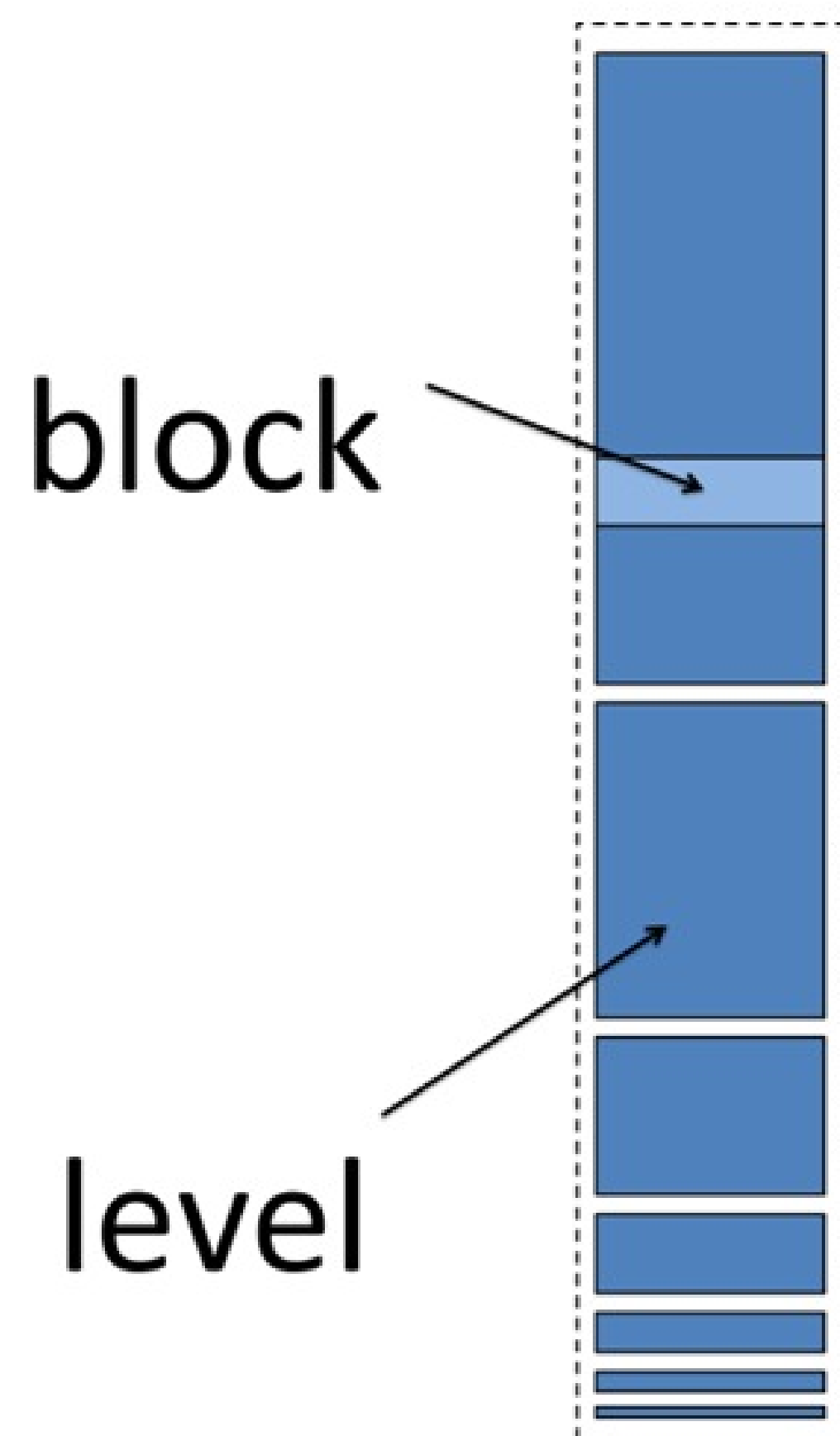
客户端
(股票交易员)



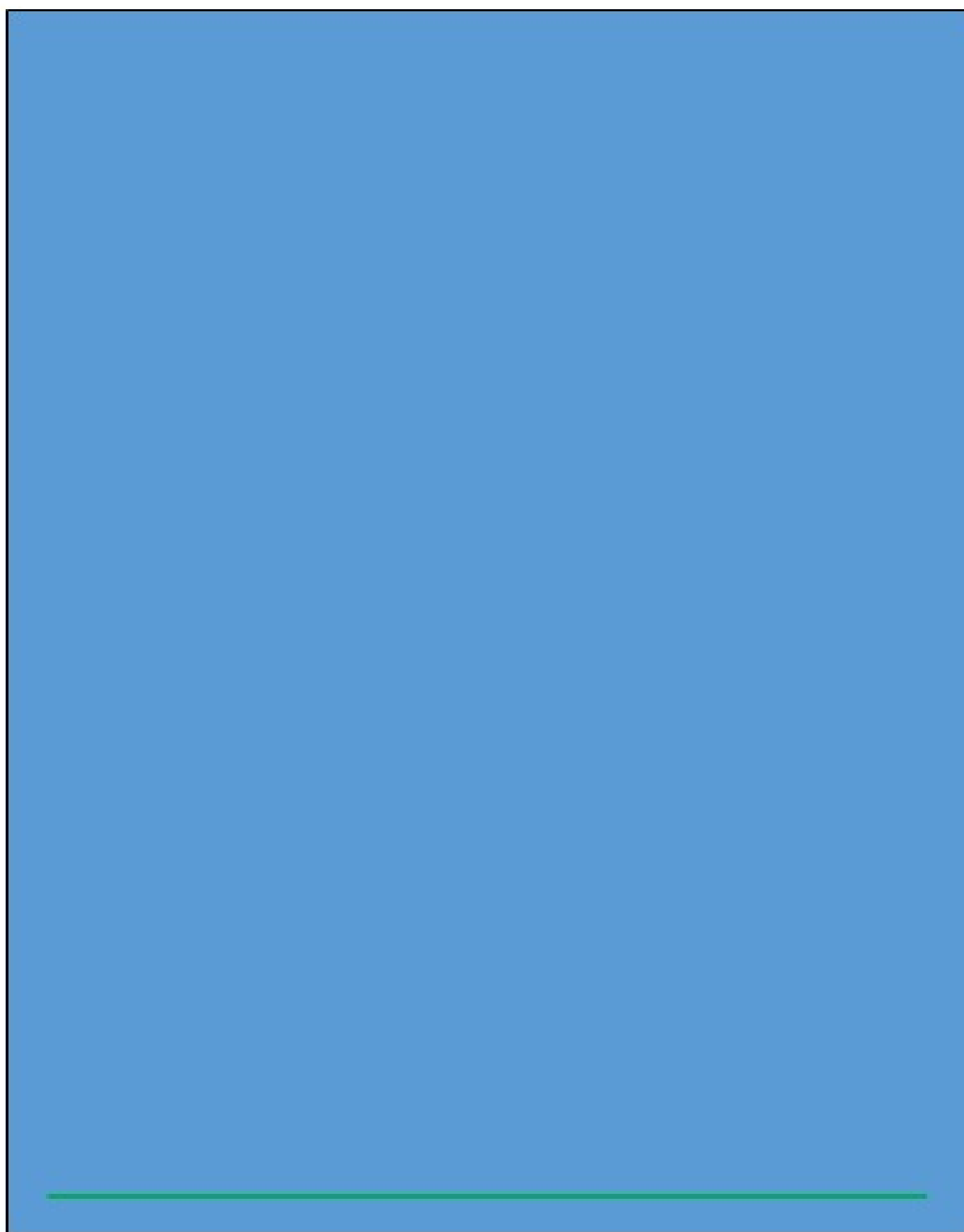
Buy IBM

Buy EMC

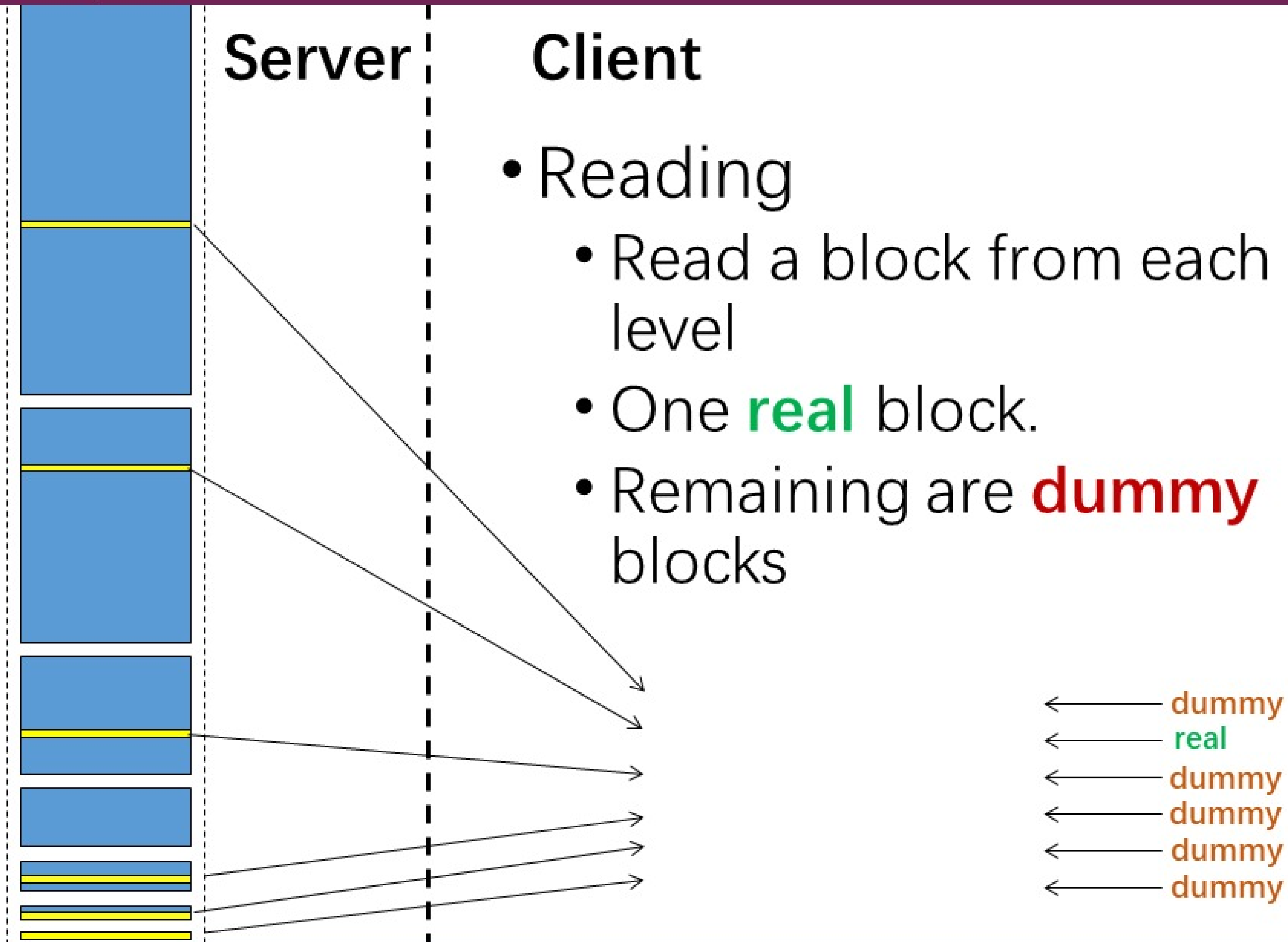
Buy IBM

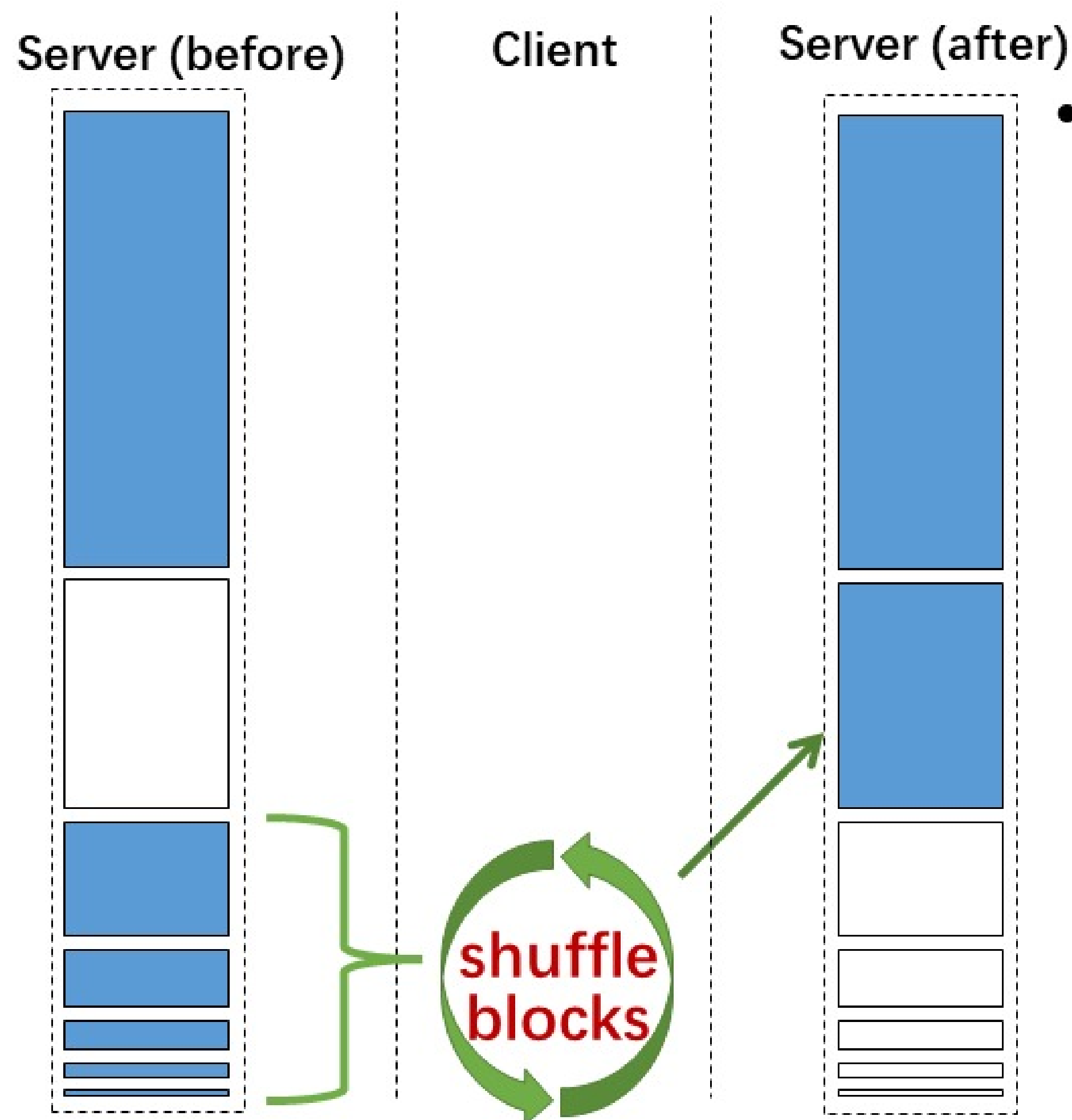


- ORAM: Oblivious random access machine
茫然随机存储器 - ORAM
- G096: Goldreich-Ostrovsky scheme.
[G096, OS97, WS08, PR10, GM10, GMOT11, BMP11, GMOT12, KLO12...]
- N 个块, 块大小一致是 ORAM 模型的前提
- $\log_2 N + 1$ levels
 - 每一层: 2^i 个块
 - Sizes: $1, 2, 4, \dots, N$



- Inside a level
 - Some real blocks
 - Useful data
 - Some dummy blocks
 - Random data
 - Randomly permuted
 - Only the client knows the permutation
 - Position map





- Writing

- Shuffle consecutively filled levels.
- Write into next unfilled level.
- Clear the source levels

Shuffle的成本很高:

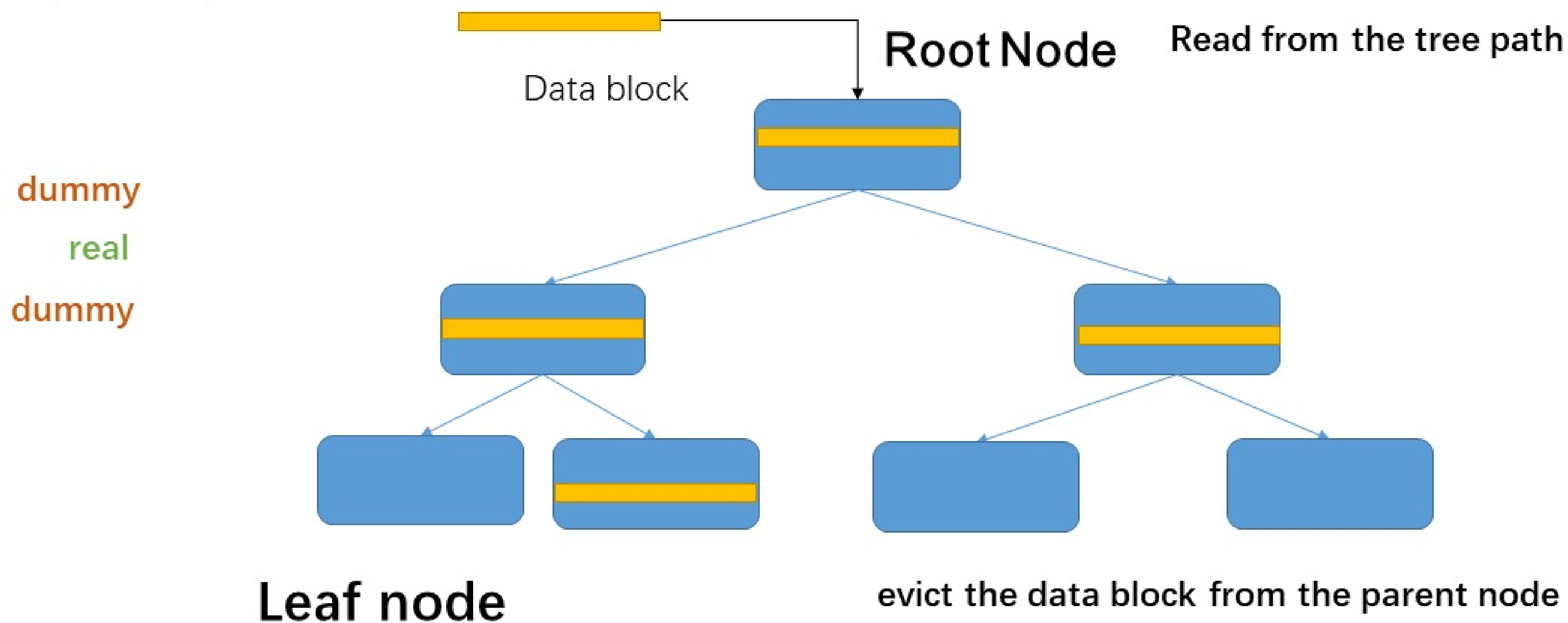
- ✓ 带宽大: 客户端download下来
- ✓ 存储高: 最坏情况所有块

有关ORAM说法错误的是

- A 一个数据块只能访问一次
- B 洗牌操作需要在客户端或者通过安全多方计算等不泄露信息的原语来完成
- C 数据块的大小可以不一样
- D 读写操作类型也需要保持一致，不能泄露信息

每个节点是一个bucket（簇或者桶），每个bucket存储很多块：真块、假块。目标：读写带宽、计算 $\log N$ 量级

Obliviously write a data block to the root

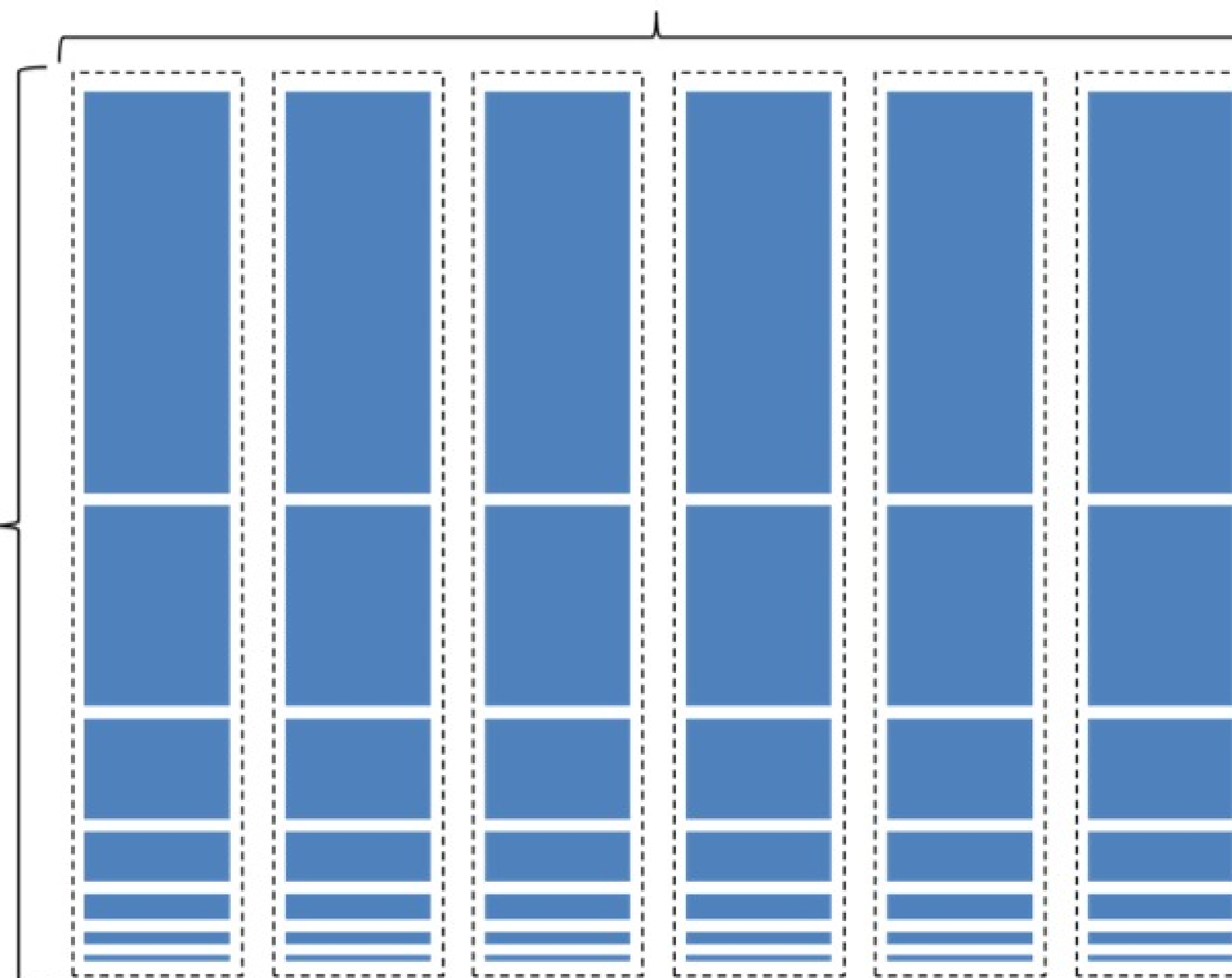


Evict的成本仍然很高，需要将一条path上的块download下来

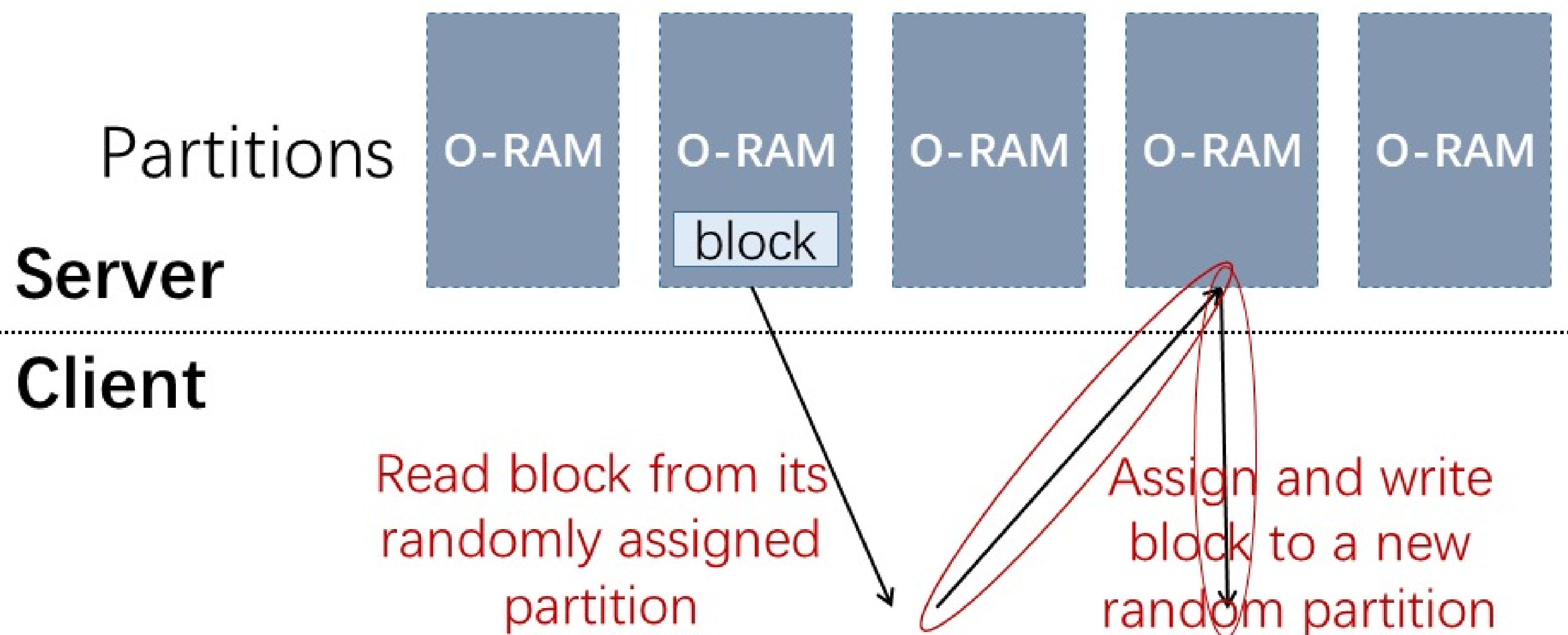
提高效率? 将N的规模变小

$\sqrt{N}$ partitions

Partitions
of size
 $O(\sqrt{N})$



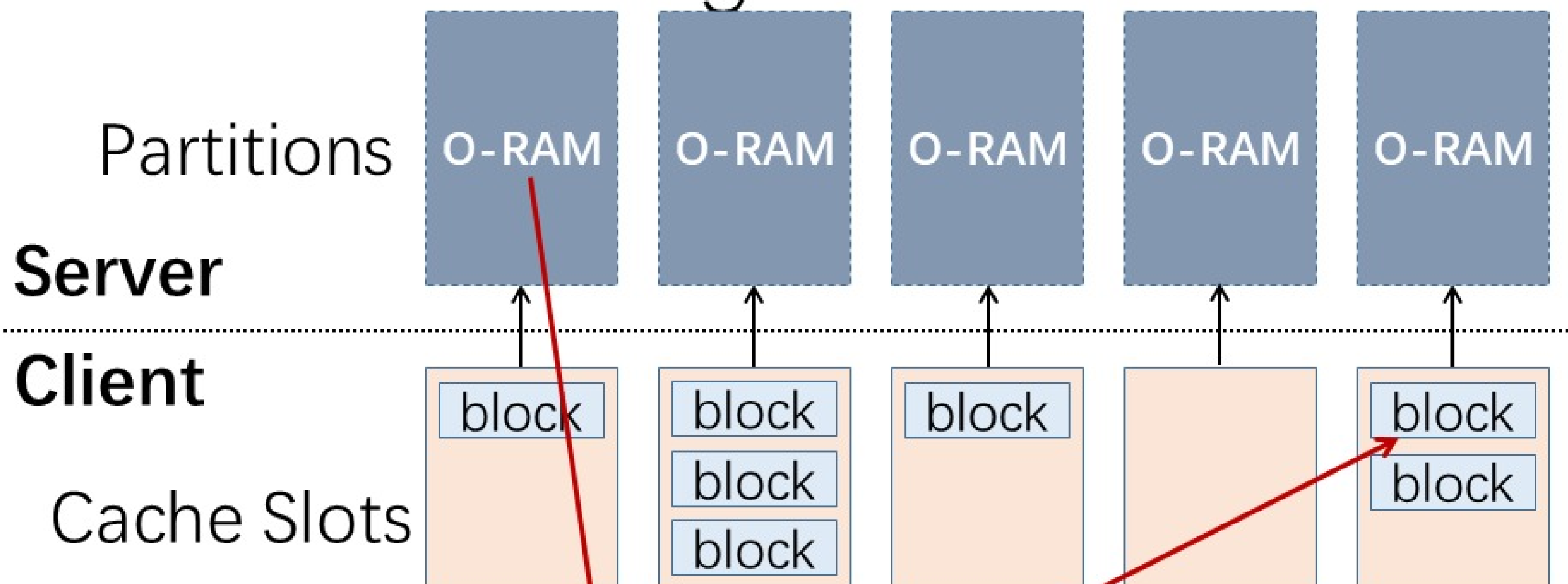
Challenge: Partitioning Breaks Security



Not privacy preserving!
Read block from its previously assigned random partition

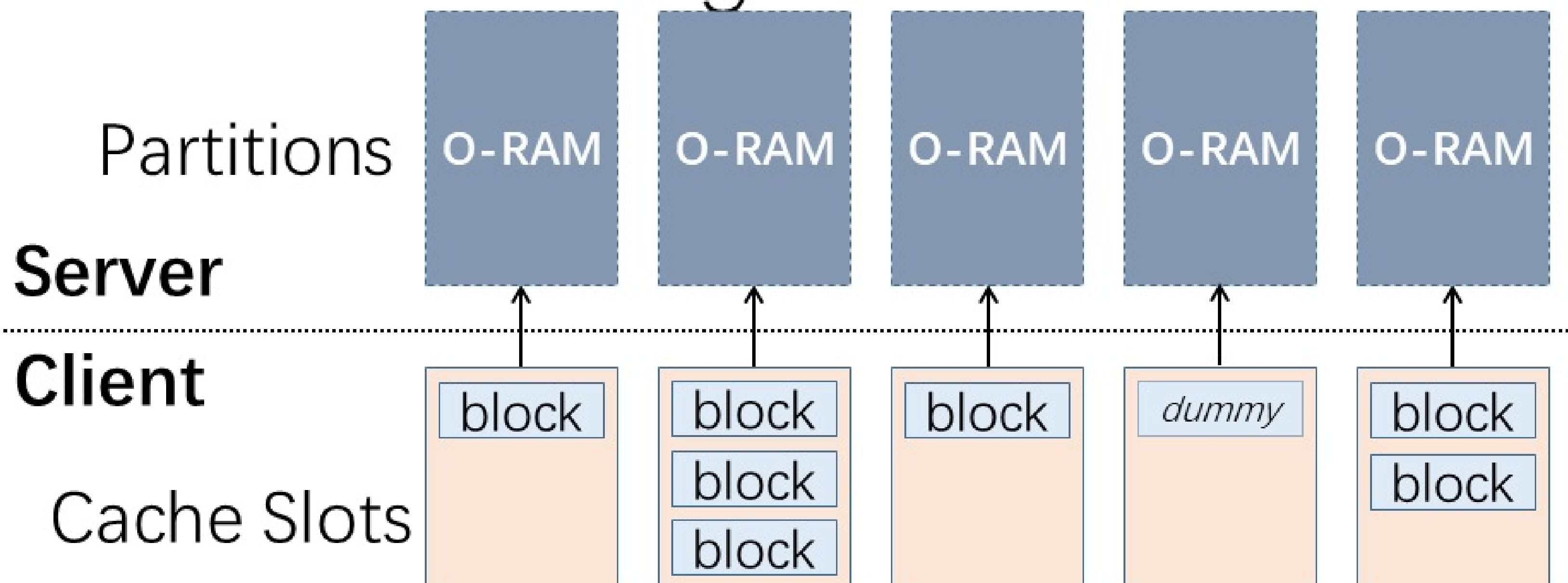
There is linkability between reads and writes.

Solution: Partitioning Framework



- Accessing a block:
 1. Read from partition (previously randomly assigned).
 2. Read/modify block data.
 3. Write to random cache slot (don't write to server yet).

Solution: Partitioning Framework



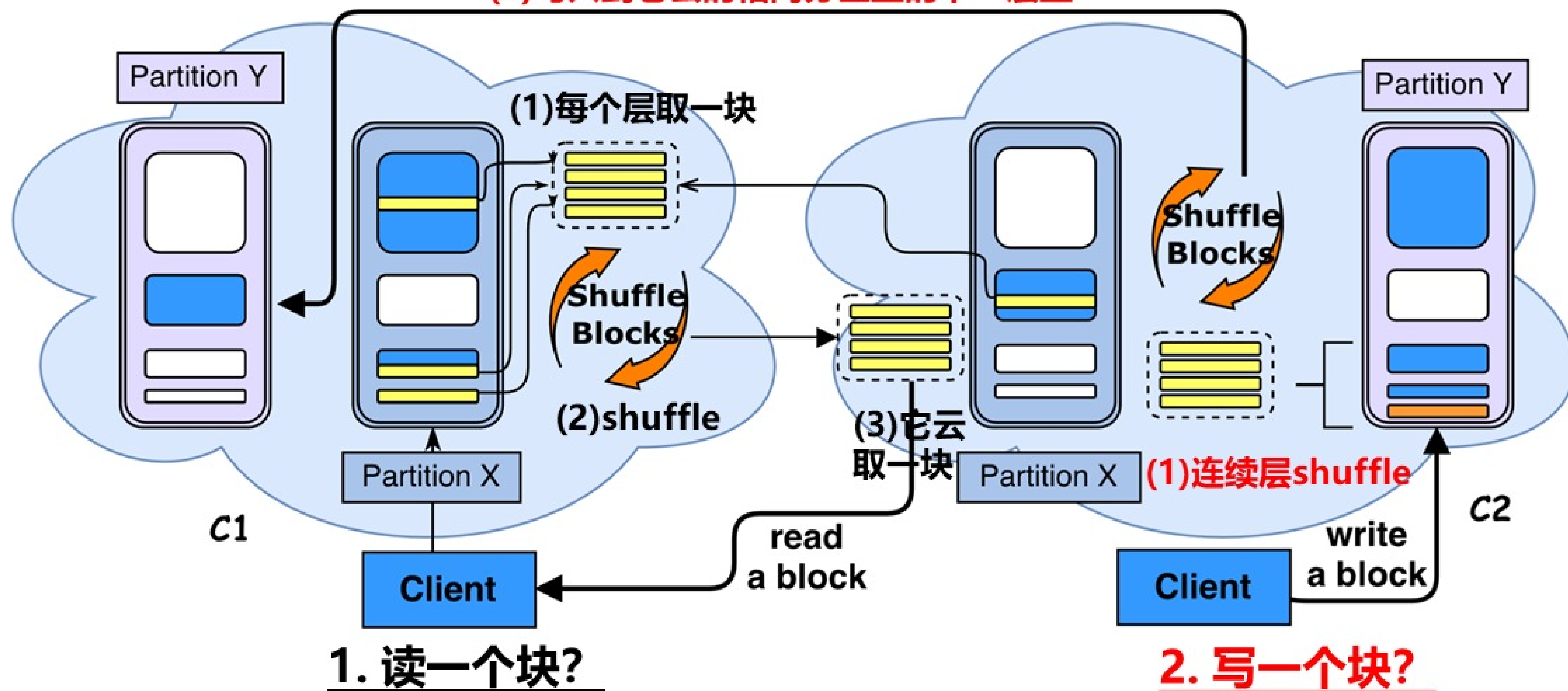
- Background eviction:
 - Sequentially scan the cache slots.
 - Evict one block if possible.
 - Evict dummy block otherwise.

有关分区ORAM说法错误的是

- A 分区ORAM通过将子ORAM的规模变大得到一定性能提升
- B 分区ORAM中的子ORAM只能是层次ORAM
- C 分区ORAM必须解决分区之间的块流动的连接问题
- D 分区ORAM通常会使用客户端的缓存来保存写回分区的块

进一步提高效率？避免客户端做大量shuffle：使用两个不共谋的云来做shuffle。两云拥有完全相同结构，共同存储

(2) 写入到它云的相同分区里的下一层里



挑战：相同分区的数据还会回写到做shuffle的云，块与块之间的连接性存在

洋葱加密：当数据块在云间进行传输交互时，**在传输到另一个云端之前**对数据块加一层洋葱层加密，**缺点是会导致洋葱加密层无上界地增加。**

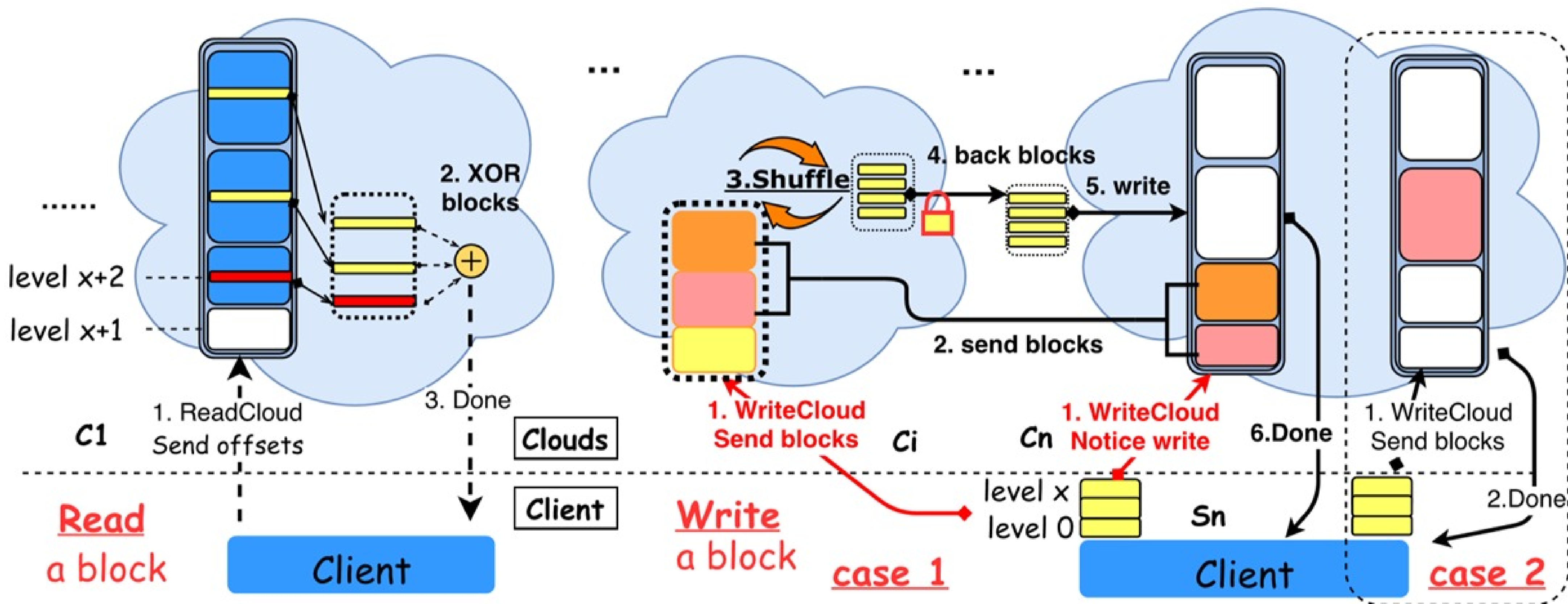
洋葱加密层剥离机制：客户端利用空闲时间将有洋葱层的块download下来剥掉洋葱，重新加密后写回到云。**缺点是：延缓了带宽的产生，仍然会带来沉重的客户端开销。**

挑战：减少洋葱加密层的次数，使洋葱层的层数具有上界；无需download到客户端。

目标：一个数据块最多有两层洋葱加密。

有关多云ORAM的洋葱加密说法错误的是

- A 洋葱加密就是多次加密，每次采用不同的密钥
- B 多云ORAM的洋葱加密是避免相同的块被识别出来
- C 对于多云ORAM而言，洋葱加密能保证安全，不再需要洗牌操作
- D 多云ORAM的多次读写加密会造成洋葱加密层的层数不一致



Read发生在单云上，采用XOR机制

Write操作： (1) 交给另外的云来shuffle，写回本云
(2) 打破连接性：不让相同的云连续做两次shuffle

C1

C2

C3

Linkability?

$E_{K1}(B1) \oplus E_{msk1}(r1)$

OKey₃

洗牌后写回来的

$E_{K1}(B1) \oplus E_{msk1}(r1)$

OKey₂

$E_{K1}(B1) \oplus E_{msk1}(r1)$

OKey₁

初始待洗牌的

Client

Source-cloud threat

基于XOR-效率高

客户端无离线操作

shuffle and
on encrypt

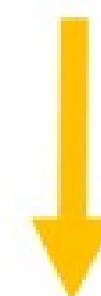
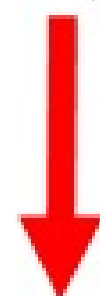
ot and XOR r1'

$\oplus E_{msk1}(r1_2)$

$E_{msk1}(r1_2)$ OKey₂, OKey₃

第三部分 ORAM实际应用

ORAM效率低 VS 可搜索加密性能要求高



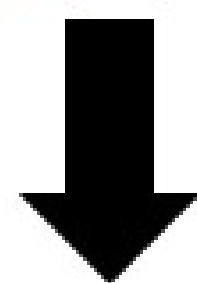
不需要每次读写操作都茫然

前向安全不安全

+

源于能识别注入的文件或索引

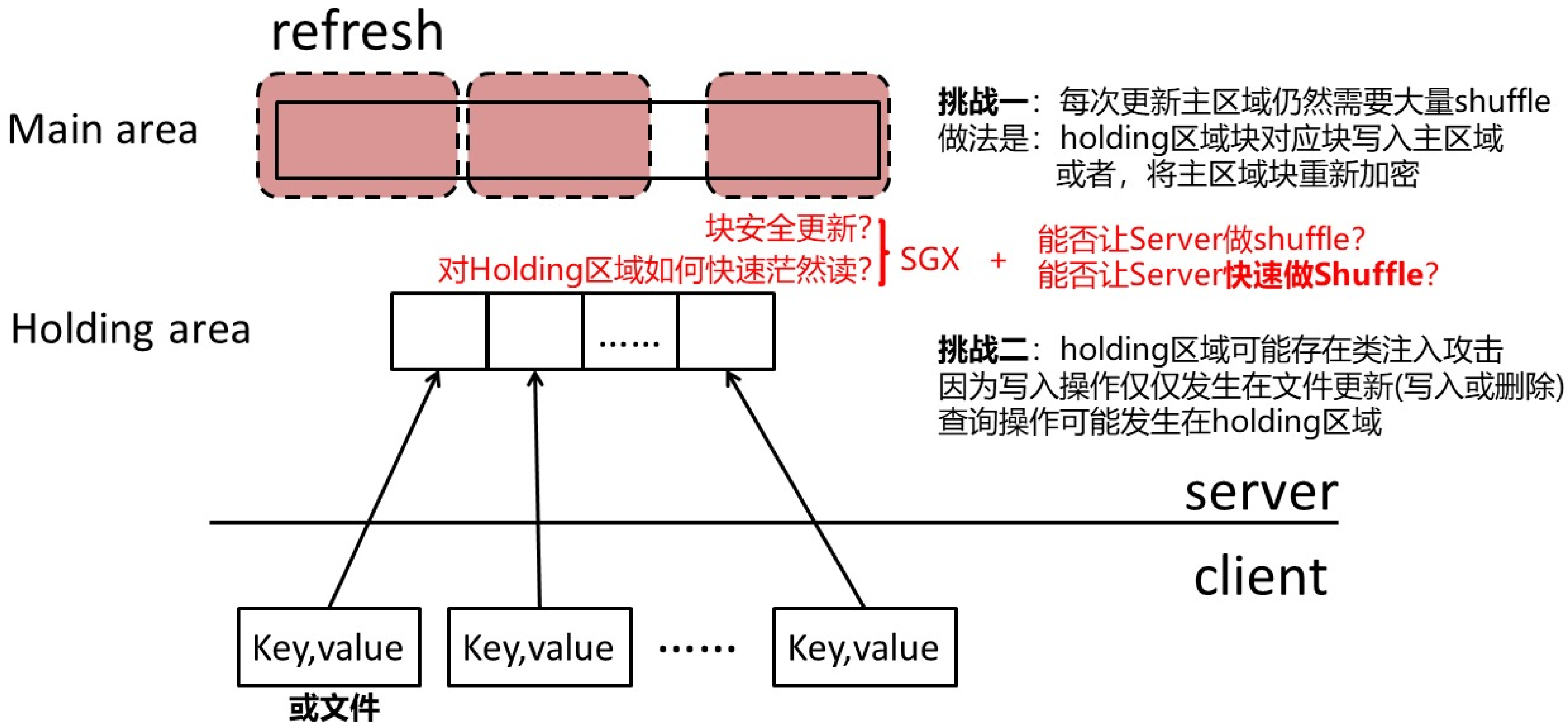
依然遭受**文件注入攻击**

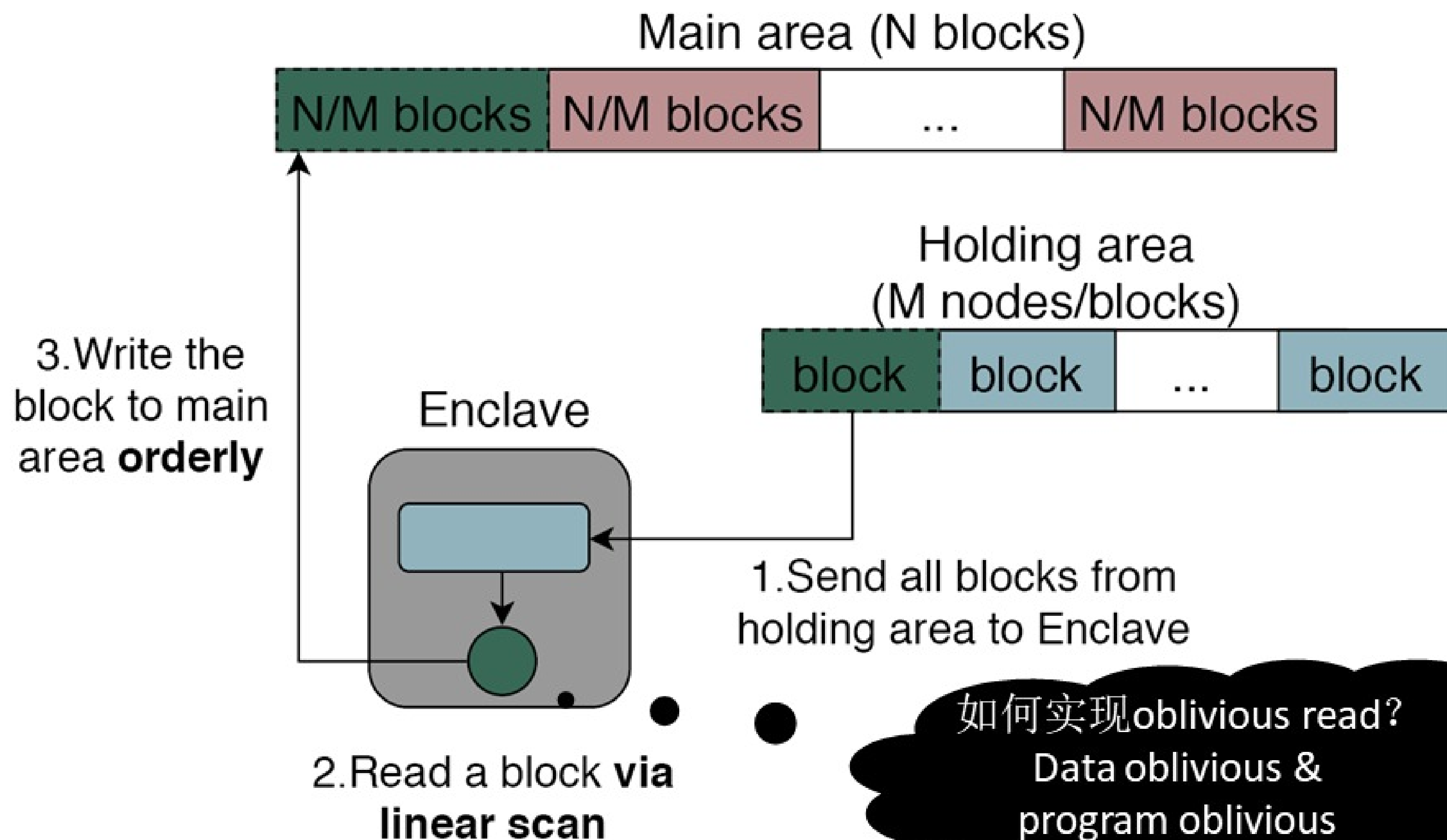


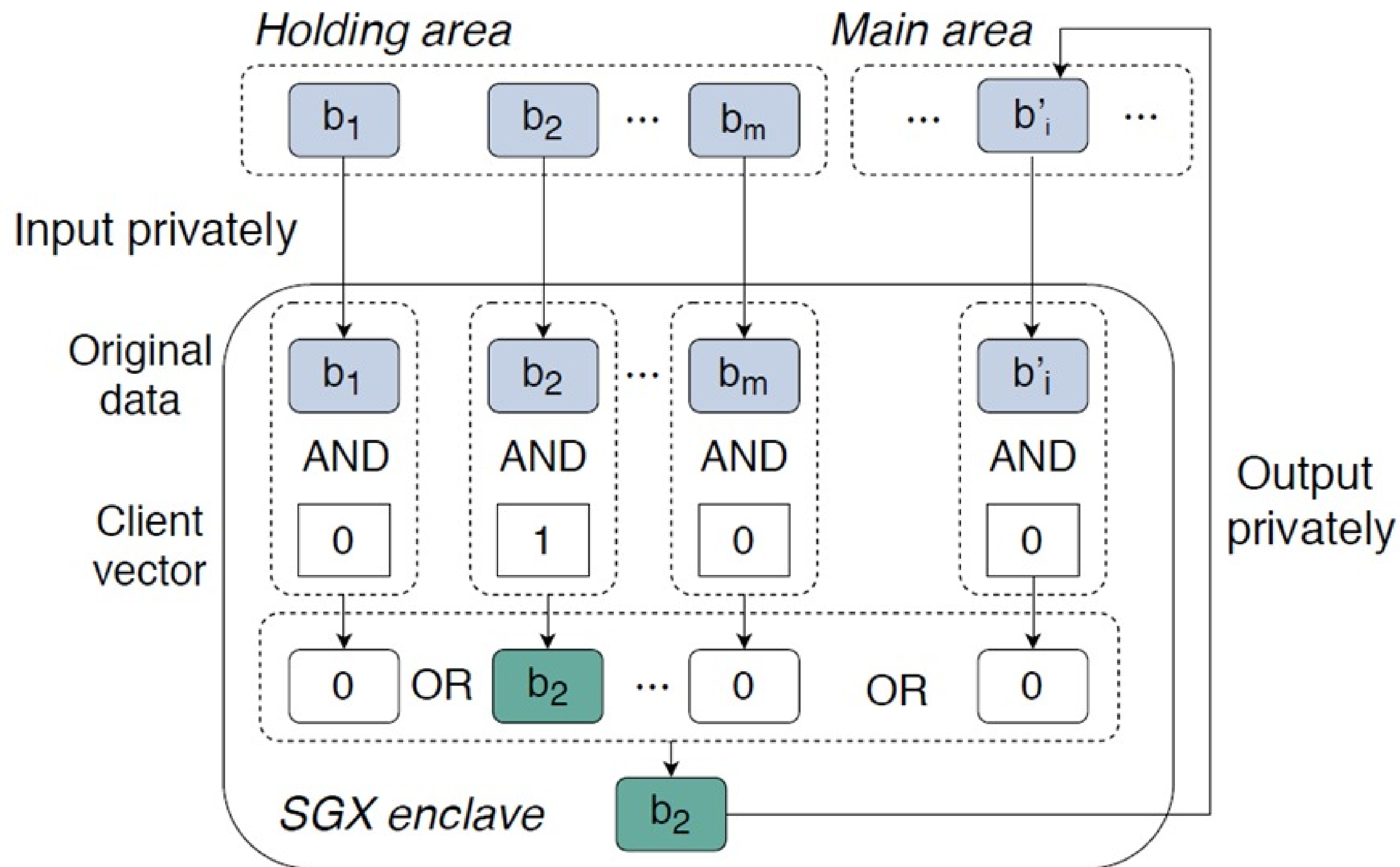
写入文件的时候，让服务器无法识别文件是哪个
之后检索的时候，无需做任何茫然的操作

缺乏高效的SSE方案

考虑只写的问题—Write only ORAM?







谢谢大家！

姓名：刘哲理

liuzheli@nankai.edu.cn

南开大学 计算机学院 网络空间安全学院

副院长